

CIA Triad

Information Security: Confidentiality, Integrity, Availability

1. Confidentiality

Confidentiality means keeping information secret. Only people who are allowed can see the data. It protects private data like passwords, medical records, and financial details from unauthorized access.

Goal

Only authorized people, systems, or processes can view protected information. Example: a student's result should be seen only by the student and university staff, not by everyone.

Ways to Ensure Confidentiality

Technique	How It Helps
Access Control	Only authorized users can access data (passwords, biometrics, role-based access)
Encryption	Converts data into unreadable form; protects data at rest and in transit
Multi-Factor Authentication (MFA)	Adds extra layer of security (password + OTP)
Data Masking / Anonymization	Hides sensitive data during sharing or processing
Network Security	Firewalls, VPN, HTTPS protect data while moving
Physical Security	Stops unauthorized physical access to servers and devices

Threats to Confidentiality

- **Hacking:** gaining access to a system without permission to steal data
- **Eavesdropping:** secretly capturing data while it is being sent over a network
- **Insider Threats:** employees misusing the access they already have
- **Social Engineering:** tricking people through fake emails or calls (phishing) to get passwords
- **Improper Data Disposal:** throwing away old devices or documents without destroying the data on them

Best Practices

- **Least Privilege Access:** give users access only to what they need for their work
- **Update Software:** install security updates on time to fix weaknesses
- **Train Staff:** teach staff to avoid clicking suspicious links or sharing OTP
- **Encrypt Data:** use HTTPS and encrypt files/messages before sending
- **Monitor & Audit:** keep records of who accessed data and when

2. Integrity

Integrity means data stays accurate, complete, and unchanged unless properly authorized. It protects data from unwanted changes caused by attackers, system errors, or human mistakes.

Why Integrity Is Important

- **Reliable Decisions:** correct data leads to correct decisions
- **Prevents Fraud:** stops manipulation like changing marks or bank records
- **Maintains Trust:** users trust a system only if data is correct

- **Legal Compliance:** banking, healthcare, and government need accurate records by law

Key Aspects of Integrity

Aspect	Meaning
Accuracy	Data must show the real, correct value (e.g., correct CGPA or bank balance)
Completeness	All required data must be present, nothing missing
Consistency	Data should match across all systems after an update

Threats to Integrity

- **Unauthorized Modification:** attackers or insiders change data without permission (e.g., changing exam marks)
- **Data Corruption:** hardware failure, bugs, or viruses damage data
- **Human Error:** mistakes made while entering or processing data
- **Transmission Errors:** data gets altered while moving through a network

Ways to Ensure Integrity

Technique	How It Helps
Checksums / Hash Functions	Detect unauthorized changes in data
Digital Signatures	Confirm sender identity and that data is unchanged
Audit Logs	Record changes so unauthorized edits can be found
Access Control	Stops unauthorized users from changing data
Database Constraints	Enforce rules like no duplicate IDs
Version Control	Tracks changes and allows rollback to correct version

Best Practices

- **Role-Based Access Control:** give edit rights only to the right roles (e.g., teacher can enter marks, not edit finance)
- **Cryptographic Tools:** use hashing and digital signatures to detect changes
- **Regular Backups:** keep copies of data so it can be restored if damaged
- **Regular Audits:** check logs and compare data regularly to catch errors early

3. Availability

Availability means information and systems must be ready to use whenever authorized users need them. It ensures there is no unwanted downtime or delay in accessing data and services.

Why Availability Is Important

- **Supports Business Operations:** if systems go down, business activities stop and money is lost
- **Ensures Customer Trust:** users expect services like websites, apps, and banking to work all the time
- **Critical for Essential Services:** hospitals, banks, and emergency systems must always stay available
- **Legal & Service Requirements:** organizations must follow service-level agreements (SLAs) with clients

Threats to Availability

- **DoS / DDoS Attacks:** attackers send huge numbers of fake requests to overload a system so real users cannot access it

- **Hardware / Software Failures:** server crash, hard disk failure, or software bugs make services temporarily unavailable
- **Natural Disasters:** floods, earthquakes, or fires damage infrastructure and cause long downtime
- **Power Outages / Network Failures:** electricity or internet problems (e.g., load shedding, ISP downtime) stop systems from working
- **Malicious Insider Actions:** employees intentionally disable servers or delete configurations to disrupt service

Ways to Ensure Availability

Technique	How It Helps
Redundancy (servers, network links)	Keeps services running even if a component fails
Load Balancing	Distributes traffic to prevent overload on any single server
Backup Power (UPS, generators)	Keeps systems operational during power failures
Disaster Recovery Plans	Provides a strategy for rapid recovery after major disruptions
DDoS Protection Services	Detects and mitigates attack traffic to keep systems online
Regular Maintenance & Monitoring	Identifies and fixes issues before they cause outages

Examples

- **DDoS on Bank:** customers cannot access online banking during a DDoS attack on a bank's website
- **Hospital System Crash:** a hospital's record system crashing during a power outage (with no backup power) risks patient lives

Best Practices

- **Failover & Redundant Infrastructure:** set up backup components (e.g., backup server, multiple ISPs) that take over automatically if the main system fails
- **Offsite & Cloud Backups:** keep data copies in remote and cloud locations so it survives fire, flood, or damage
- **Test DR/BCP Plans:** regularly test disaster recovery (DR) and business continuity plans (BCP) with drills and simulations
- **Monitor Systems 24/7:** watch systems continuously with alerts for high load or unusual traffic to catch problems early
- **Use SLAs:** use formal agreements with providers (e.g., 99.9% uptime) to guarantee reliable service

Quick Summary Table

Principle	Meaning	Main Threat	Main Protection
Confidentiality	Keep data secret	Hacking, Phishing	Encryption, Access Control
Integrity	Keep data accurate & unchanged	Unauthorized Modification	Hashing, Digital Signature
Availability	Keep systems accessible	DoS/DDoS, Disasters	Redundancy, Backups